

گزارش ممیزی فنی

تحلیل جامع سایت و داشبورد سپاهان فلز

رابط کاربری و تجربه کاربری · فرانت‌اند · بک‌اند

دامنه: sepahanfelez.ir

پشته فنی: [Laravel 8](#) · [PHP 7.4](#) · [Bootstrap 5](#) · [MySQL](#)

دامنه بررسی: [۱۳۰ قالب ۷۶](#) · [Blade کنترلر ۴۰۰](#) مدل · [۳۸۱۸ خط SCSS](#)

اندازه‌گیری زنده: [۸ صفحه × ۲](#) دستگاه با مرورگر واقعی

تاریخ: [۱۵ مرداد ۱۴۰۵](#) / [۶ آگوست ۲۰۲۶](#)

این گزارش بر پایه‌ی خواندن کد منبع و اندازه‌گیری مستقیم سایت زنده تهیه شده است — نه تخمین.

فهرست مطالب

۱	خلاصه اجرایی و کارنامه
۲	روش‌شناسی و دامنه بررسی
۳	ده یافته‌ی بحرانی – به ترتیب اولویت
۴	تحلیل رابط و تجربه کاربری (UI/UX)
۵	تحلیل فرانت‌اند
۶	تحلیل بک‌اند
۷	امنیت
۸	داشبورد مدیریت
۹	نقشه راه اصلاح – چهار موج
۱۰	پیوست: اعداد اندازه‌گیری‌شده

۱ خلاصه اجرایی و کارنامه

سپاهان فلز یک سایت B2B فروش مفتول و توری فولادی است که هسته‌ی ارزش آن «جدول قیمت لحظه‌ای» است. معماری کلی سالم و حرفه‌ای است؛ لایه‌بندی درست Laravel، سیستم نقش و دسترسی واقعی، خط لوله‌ی CI/CD خودکار، و یک هویت بصری منسجم روی دسکتاپ. **روی دسکتاپ سایت خوب کار می‌کند.**

اما سه مشکل ساختاری، ارزش این پایه‌ی خوب را می‌بلعند: (۱) تجربه‌ی موبایل عملاً شکسته است – اندازه‌ی متن پایه روی موبایل ۸.۴ پیکسل است و جدول قیمت (یعنی خود محصول) در ویوپورت موبایل جا نمی‌شود؛ (۲) پشته‌ی اجرایی از پشتیبانی خارج شده – PHP 7.4 و Laravel 8 هر دو از سال ۲۰۲۲/۲۰۲۳ دیگر وصله‌ی امنیتی نمی‌گیرند؛ (۳) چند باگ کوچک اما پرتکرار در بک‌اند و جاوااسکریپت باعث شده کش‌ها هیچ‌وقت کار نکنند و یک خطا هر ثانیه روی تمام صفحات پرتاب شود.

کارنامه‌ی حوزه‌ها

28		تجربه کاربری موبایل	72		تجربه کاربری دسکتاپ
38		کارایی و Core Web Vitals	31		دسترسی پذیری (a11y)
54		معماری و کیفیت بک‌اند	44		معماری فرانت‌اند
56		داشبورد مدیریت	42		امنیت
46		میانگین وزنی	68		زیرساخت و استقرار

۲۶

نقطه‌ی قوت

۳۱

یافته‌ی متوسط

۲۴

یافته‌ی با اولویت زیاد

۱۰

یافته‌ی بحرانی

یک جمله برای مدیر

اگر فقط بودجه‌ی یک هفته کار وجود دارد، آن را صرف **موج ۱** (بند ۹) کنید: اصلاح مقیاس فونت موبایل، جدول قیمت موبایل، لوگوی قدیمی صفحات ورود، و خطای ساعت. این چهار مورد با کمتر از ۲ روز کار، بزرگ‌ترین جهش کیفیت قابل‌مشاهده را می‌دهند.

۲ روش‌شناسی و دامنه بررسی

این گزارش از دو منبع مستقل ساخته شده است تا ادعاها قابل راستی‌آزمایی باشند:

الف) تحلیل کد منبع

مخزن `ahanamn-src` به طور کامل خوانده شد:

لایه	حجم	آنچه بررسی شد
مسیرها (Routes)	۳۹۲ خط	روت‌های سایت، پنل کاربر، ۹۶ روت ادمین با میان‌افزار <code>can:</code>
کنترلرها	۷۶ فایل	سه دامنه: <code>Site / AdminPanel / UserPanel</code>
مدل‌ها	۴۰ فایل	روابط، <code>\$fillable</code> ، هوک‌های <code>boot()</code>
قالب‌ها	۱۳۰ Blade	خروجی <code>unescape</code> شده، فرم‌ها، دسترس‌پذیری، <code>N+1</code> در حلقه‌ها
استایل	۱۸ فایل / ۳۸۱۸ خط SCSS	توکن‌ها، <code>breakpoint</code> ها، مقیاس تایپوگرافی
جاوااسکریپت	۱۹ فایل مبدأ	خروجی ساخته‌شده و پی‌کربندی <code>Laravel Mix</code>
مهاجرت‌ها	۵۰ فایل	ایندکس‌ها، کلیدهای خارجی، طرح جدول

ب) اندازه‌گیری سایت زنده

هشت صفحه با مرورگر واقعی (Chromium) در دو ویوپورت بارگذاری و اندازه‌گیری شد — موبایل `375x812` با `User-Agent` آیفون، و دسکتاپ `1440x900`. برای هر صفحه اندازه‌ی محاسبه‌شده‌ی هر المان، نسبت کنتراست هر جفت متن/پس‌زمینه، ابعاد هر هدف لمسی، و معیارهای `LCP / CLS / TTFB / longtask` از `PerformanceObserver` استخراج شد.

صفحات: `/` `price/` `blog/` `about/` `contact/` `login/` `/category/` `category/سیم-خاردار`

آنچه در دامنه‌ی این گزارش نیست

داشبورد مدیریت از روی کد تحلیل شده و نه با ورود زنده — ورود به پنل نیازمند کد پیامکی دودقیقه‌ای روی موبایل مالک است. همچنین اعداد کارایی آزمایشگاهی (lab) هستند نه میدانی (field)، چون دسترسی به `Search Console` و `GA4` این دامنه در اختیار نبوده است.

۳ ده یافته‌ی بحرانی — به ترتیب اولویت

#	یافته	اثر	حوزه	تلاش
۱	اندازه‌ی فونت پایه روی موبایل ۸.۴ پیکسل است <code>html{font-size:6px}</code> زیر ۳۷۵px و 7px تا ۴۲۵px؛ بدنه <code>1.4rem</code>	۱۳۷ تا ۱۸۵ المان متنی زیر ۱۴px در هر صفحه؛ سایت روی موبایل تقریباً ناخوانا	UI	۱ روز
۲	جدول قیمت در ویوپورت موبایل جا نمی‌شود <code>min-width:992px</code> روی جدول در ویوپورت ۳۷۵px	کاربر موبایل در صفحه‌ی اصلی فقط ستون «نام» را می‌بیند — قیمت، نوسان و دکمه‌ی خرید نامرئی‌اند	UI	۲ روز
۳	PHP 7.4 و Laravel 8 هر دو End-of-Life هستند PHP 7.4: نوامبر ۲۰۲۲ — Laravel 8: ژانویه ۲۰۲۳	هیچ وصله‌ی امنیتی جدیدی دریافت نمی‌شود؛ هر CVE کشف‌شده تا ابد باز می‌ماند	Back	۳-۴ هفته
۴	لوگوی برند قبلی «آهن امن» هنوز روی ۴ صفحه‌ی ورود/ثبت‌نام است <code>images/logo.png</code> در <code>login</code> ، <code>register</code> و دو صفحه‌ی تأیید کد	پاک‌سازی برند متن را گرفت ولی تصاویر را نه؛ کاربری که وارد می‌شود لوگوی شرکت دیگری را می‌بیند	UI	۱ ساعت

#	یافته	اثر	حوزه	تلاش
۵	خطای جاوااسکریپت هر ثانیه روی تمام صفحات live-time.js روی #time_counter1 که در قالب کامنت شده - setInterval تا ابد throw می‌کند	ساعت «لحظه‌ای» صفحه اصلی روی مقدار hardcoded شده‌ی 16:45:22 یخ زده است - روی سایتی که ادعای «قیمت لحظه‌ای» دارد	FE	۱۵ دقیقه
۶	CLS بین ۰.۳۲ تا ۰.۷۳ (هدف <۰.۱) موبایل = ۰.۷۲۶ / price = صفحه اصلی = ۰.۳۲۵۰۰۴۰۸ / about =	۲۹ تا ۳۸ تصویر بدون width/height؛ محتوا زیر انگشت کاربر می‌پرد. رتبه‌ی Google هم آسیب می‌بیند	FE	۲ روز
۷	هیچ محدودیت نرخ روی تأیید کد پیامکی نیست روت /verify-phone بدون throttle؛ کد ۶ رقمی، پنجره ۲ دقیقه	حدس زدن کد ورود امکان‌پذیر است. کد پس از ورود موفق هم حذف نمی‌شود و تا انقضای دوباره قابل استفاده است	Sec	۳ ساعت
۸	آپلود SVG در ۱۷ نقطه مجاز است mimes: jpg, bmp, png, svg, jpeg - شامل آواتار و پیوست تیکت کاربر عادی	فایل SVG می‌تواند <script> داشته باشد و از همان دامنه سرو می‌شود → XSS ذخیره شده	Sec	۲ ساعت
۹	سه باگ کش که کش را کاملاً بی‌اثر کرده‌اند کلید redirection نوشته و redirections خوانده می‌شود - home.all_prices هرگز نوشته نمی‌شود - TTL برابر now()->second() یعنی عددی تصادفی بین ۰ تا ۵۹ ثانیه	پرسوجوی جدول redirects در هر درخواست اجرا می‌شود؛ کوئری سنگین صفحه‌ی اصلی هرگز کش نمی‌شود. TTFB موبایل ۱۵۴۰ms	Back	۳ ساعت
۱۰	ساخت کامل sitemap در هر ذخیره‌ی قیمت هوک updated روی Category و Product و Article → Sitemap::generate()	هر بار که قیمتی به‌روز شود، تمام دسته‌ها، محصولات و مقالات دوباره خوانده و کل فایل بازنویسی می‌شود - همان مسیری که پیش‌تر برای دستکاری sitemap سوءاستفاده شد	Back	۱ روز

۴ تحلیل رابط و تجربه کاربری

۴.۱ نقاط قوت

- هویت بصری منسجم روی دسکتاپ. پالت چهاررنگی محدود و منضبط (#b42332 قرمز برند، #283264 سرمه‌ای، #495f9e آبی، #f7f7f7 خاکستری) که در تمام صفحات یکسان به‌کار رفته است. این نظم رنگی در پروژه‌های این مقیاس کم‌پیدا است.
- ست آیکون یکدست برای ۱۴ دسته محصول. همه خط‌نقاشی (line-art) با ضخامت یکسان داخل کادر قرمز. اصل «یک زبان آیکونی» رعایت شده - نه ایموجی، نه مخلوط filled/outline.
- نوسان قیمت فقط با رنگ منتقل نمی‌شود. کنار درصد سبز/قرمز، آیکون مثلث بالا/پایین هم هست. این دقیقاً قاعده‌ی color-not-only در WCAG است و اغلب سایت‌های مالی آن را نقض می‌کنند.
- جدول قیمت دسکتاپ واقعاً خوب است. هفت ستون معنادار (نام، قیمت لحظه‌ای، نوسان، نمودار، آخرین تغییر، خرید) با اسپارک‌لاین درون خطی و مودال نمودار تفصیلی برای هر محصول.
- «چاپ گزارش» با استایل‌شیت اختصاصی. فایل print.scss جداگانه و print.js - یک نیاز واقعی B2B که معمولاً فراموش می‌شود.
- RTL درست پیاده شده. Bootstrap 5، lang="fa"، dir="rtl" در حالت RTL بومی، اعداد فارسی، و فونت IRANSans با نسخه‌ی FaNum (ارقام فارسی داخل فونت).
- فیلتر مشخصات فنی روی صفحه‌ی دسته. کاربر می‌تواند بر اساس ضخامت مفتول، نوع گالوانیزه، ضخامت خار و... محصول را محدود کند - دقیقاً الگوی درست برای کالای صنعتی.
- breadcrumb به‌همراه JSON-LD. صفحات دسته هم مسیر بصری دارند هم BreadcrumbList و CollectionPage ساختاریافته.
- کانال ارتباط سریع. دکمه‌ی شناور واتس‌آپ و چت Goftino - برای فروش B2B مسیر تماس کوتاه است.
- منوی کشویی موبایل (sidemenu) با سلسله‌مراتب سه‌سطحی که ساختار دسته‌بندی عمیق را درست بازتاب می‌دهد.

■ مقیاس تایپوگرافی – بحرانی‌ترین مشکل کل سایت

فایل `_media-Queries.scss` اندازه‌ی فونت ریشه را بر اساس عرض صفحه تغییر می‌دهد. چون این فایل آخرین `import` در `main.scss` است، مقدار `14px` در `_base.scss` را بازنویسی می‌کند. نتیجه (اعداد ستون آخر، اندازه‌گیری زنده است):

عرض صفحه	font-size ریشه	اندازه‌ی بدنه (1.4rem)	وضعیت
تا ۳۷۵px (آیفون SE / مینی)	6px	۸.۴px	ناخوانا
۳۷۶ تا ۴۲۵px (اکثر گوشی‌ها)	7px	۹.۸px	ناخوانا
۴۲۶ تا ۷۶۸px (تبلت)	8px	۱۱.۲px	خیلی کوچک
۷۶۹ تا ۱۰۲۴px	9px	۱۲.۶px	کوچک
۱۰۲۵ تا ۱۴۴۰px	10px	۱۴px	حداقل قابل قبول
بالای ۱۴۴۰px	11px	۱۵.۴px	قابل قبول

سه پیامد جداگانه دارد:

- **خوانایی.** شمارش زنده روی موبایل: صفحه اصلی ۱۳۷، صفحه قیمت ۱۸۵، صفحه دسته ۱۲۵ المان متنی زیر ۱۴ پیکسل. حداقل توصیه‌شده برای متن بدنه ۱۶px است.
- **زوم خودکار iOS.** سافاری هر ورودی با فونت زیر ۱۶px را هنگام فوکوس زوم می‌کند – یعنی هر بار که کاربر روی جستجو یا فرم تماس ضربه بزند، صفحه می‌پرد.
- **نقض تنظیمات کاربر.** تعیین `font-size` بر حسب پیکسل روی `html`، تنظیم «اندازه‌ی فونت» مرورگر کاربر را بی‌اثر می‌کند. این نقض معیار WCAG 1.4.4 است.

راه‌حل پیشنهادی

مقدار ریشه را روی 100% (یعنی ۱۶px پیش‌فرض مرورگر) بگذارید و مقیاس واکنش‌گرا را با `clamp()` روی خود کلاس‌های متن بسازید، نه روی ریشه. چون تمام اندازه‌های موجود `rem` هستند، این تغییر متمرکز است – اما باید با یک بازبینی بصری کامل همراه شود، چون تمام فاصله‌ها هم `rem` هستند و جابه‌جا می‌شوند.

■ جدول قیمت روی موبایل

کلاس `separated-table table` در `_variables.scss` مقدار `min-width: 992px` دارد. در ویوپورت ۳۷۵ پیکسلی این یعنی جدول ۲.۶ برابر عرض صفحه است. اسکرین‌شات موبایل صفحه‌ی اصلی نشان می‌دهد کاربر فقط ستون «نام» و لبه‌ی یک ستون دیگر را می‌بیند – قیمت، درصد نوسان و دکمه‌ی خرید کلاً بیرون کادرند.

شمارش زنده: ۲۵۶ المان در صفحه‌ی `/price` و ۱۶۷ المان در صفحه‌ی اصلی، بیرون از مرز ویوپورت قرار دارند.

پیشنهاد: زیر ۷۶۸px جدول را به کارت تبدیل کنید – هر محصول یک کارت با نام (تیترا)، قیمت (بزرگ)، نوسان (چپ رنگی+آیکون) و دکمه‌ی خرید. این الگوی استاندارد جدول‌های داده روی موبایل است و به‌جای اسکرول افقی، اسکرول عمودی طبیعی می‌دهد.

■ هدف‌های لمسی

صفحه (موبایل)	عناصر تعاملی	زیر ۴۴pxx۴۴px	درصد
صفحه اصلی	۱۰۶	۶۳	۵۹%
price/	۱۴۱	۹۲	۶۵%
category/سیم-خاردار	۸۶	۴۹	۵۷%
blog/	۸۲	۴۸	۵۹%

حداقل استاندارد ۴۴×۴۴ نقطه (اپل) یا ۴۸×۴۸ (متریال) است. این مستقیماً پیامد مشکل قبلی است: وقتی `1rem = 6px` شود، دکمه‌ای که با padding بر حسب rem ساخته شده هم کوچک می‌شود.

دسترس‌پذیری

مورد	یافته	شدت
لینک پرش (skip link)	در هیچ صفحه‌ای وجود ندارد — کاربر کیبورد باید هر بار از کل منوی سه‌سطحی رد شود	زیاد
لندمارک <code><main></code>	در صفحه‌ای اصلی اصلاً نیست (در بقیه هست)	متوسط
دکمه‌های فقط‌آیکون	۱۶ مورد در صفحه اصلی و ۲۴ مورد در <code>/price</code> بدون <code>aria-label</code> یا متن	زیاد
سرتیتر <code>h1</code>	در <code>/login</code> ، <code>/blog</code> ، <code>/about</code> ، <code>/contact</code> هیچ <code>h1</code> وجود ندارد	زیاد
ترتیب سرتیترها	پرش <code>h1→h3</code> در صفحه اصلی و <code>/price</code> ؛ <code>h2→h4</code> در <code>/contact</code>	متوسط
معناشناسی جدول	هیچ <code><th scope></code> و هیچ <code><caption></code> از ۲۱ ردیف جدول قیمت	زیاد
اعلام خطای فرم	<code>aria-live</code> در کل سایت صفر بار استفاده شده — screen reader خطای فرم را نمی‌شنود	زیاد
متن جایگزین تصویر	۱۵ تصویر بدون <code>alt</code> در <code>/category/</code> ؛ همچنین باگ الگوی "تصویر ..." در قالب دسته	متوسط
ابعاد تصویر	۲۹ تا ۳۸ تصویر در هر صفحه بدون <code>width/height</code>	زیاد
برچسب فرم	صفحه ورود فقط <code>placeholder</code> دارد و برچسب دیدنی ندارد	متوسط
<code>autocomplete</code>	۷ فیلد در فرم دسته‌بندی و ۱ فیلد جستجو بدون <code>autocomplete</code>	کم
<code>prefers-reduced-motion</code>	در هیچ‌جای SCSS رعایت نشده — اسلایدر و انیمیشن‌ها برای کاربران حساس به حرکت خاموش نمی‌شوند	متوسط

کنتراست رنگ

خبر خوب: تعداد نقض واقعی کم است. اما دو مورد جدی وجود دارد:

- «افزایش» سبز روی سفید = ۲.۱:۱ (حداقل لازم ۴.۵:۱). رنگ `#23cf14` برای متن روی زمینه‌ی روشن بیش از حد روشن است. راه‌حل: `#15803d` که همان معنی را می‌رساند و به ۵.۴:۱ می‌رسد.
- قیمت سبز روی خاکستری در صفحه‌ی دسته = ۱.۸۹:۱ — همان مشکل، در جای حساس‌تری (خود قیمت).
- کنتراست وابسته به تصویر. شماره تلفن هدر با `color:#b42332` (قرمز) نوشته شده و فقط به این دلیل خوانا است که تصویر `wrapper.webp` یک ریون سفید پشتش می‌گذارد. اگر آن تصویر لود نشود، متن قرمز روی نوار قرمز = نامرئی. این تکنیکی شکننده است.
- صفحه ورود کل خوانایی‌اش را از تصویر پس‌زمینه‌ی `bg-2.jpg` (۲۳۷ کیلوبایت) می‌گیرد. اگر تصویر دیر بیاید یا خطا بدهد، متن سفید روی زمینه‌ی `#eef0f8` با نسبت ۱.۱۴:۱ باقی می‌ماند — عملاً نامرئی.

سایر مسائل تجربه کاربری

- لوگو روی موبایل اصلاً نمایش داده نمی‌شود. کلاس `d-none d-lg-block` روی تصویر لوگو یعنی زیر ۹۹۲px هیچ نشان برندی در هدر نیست — کاربر موبایل نمی‌داند در سایت کیست.
- تناقض پیام اصلی. تیتر «قیمت لحظه‌ای» و «جدول تغییرات لحظه‌ای» است، اما ستون «آخرین تغییر قیمت» روی تمام ردیف‌ها «۲ ماه پیش» نشان می‌دهد. این بزرگ‌ترین ضربه به اعتماد در کل سایت است — یا داده باید تازه شود یا عنوان باید صادقانه شود.
- ساعت یخ‌زده. کنار همان تیتر، ساعتی است که روی `16:45:22` ثابت مانده چون مقدارش در خود قالب `hardcode` شده و اسکریپتی که قرار بوده به‌روزش کند، کرش می‌کند (بند ۵.۲).
- مسیر طولانی تا محصول در موبایل. در `/price` کاربر موبایل باید از ۱۴ کاشی دسته‌بندی (در دو ستون، حدود ۷ ردیف) رد شود تا به جدول قیمت برسد. کاشی «همه محصولات» هم برخلاف بقیه آیکون ندارد.
- سرریز افقی در `/blog` موبایل: عرض اسکرول ۹۲۳px در ویوپورت ۳۷۵px.
- اعداد بدون `font-variant-numeric: tabular-nums` — ستون قیمت‌ها هم‌تراز نمی‌شود و هنگام به‌روزرسانی می‌لرزد.
- نمودارها بدون `tooltip`، بدون برچسب مستقیم، و بدون حالت «داده‌ای نیست» — اسپارک‌لاین‌ها هیچ مقدار عددی‌ای منتقل نمی‌کنند.

- عدم وجود حالت خالی (empty state) طراحی شده برای سبد خرید خالی، نتیجه‌ی جستجوی بی‌نتیجه، و فیلتر بدون نتیجه.

۵ تحلیل فرانت‌اند

۵.۱ نقاط قوت

1. SCSS ماژولار و منظم. ۱۸ فایل partial با مرزبندی معنادار (هدر/فوتر، لندینگ، جدول قیمت، سبد، بلاگ، پروفایل، ...) – نه یک فایل هزارخطی.
2. Cache-busting درست. کلاس `App\Support\Asset::url()` زمان تغییر فایل (mtime) را به URL اضافه می‌کند. با توجه به اینکه سرور هدر `max-age=604800` می‌فرستد، این یک راه‌حل ضروری و درست است.
3. لوگو با `<picture>` و `srcset` سه‌اندازه‌ای. SVG با fallback به PNG در `۲۱۶/۸۶۴/۱۷۲۸` پیکسل، همراه با `sizes` و `width/height` برای رزرو فضا. این یکی از تمیزترین بخش‌های کد است.
4. Bootstrap 5 با RTL بومی به‌جای وارونه‌سازی دستی – انتخاب فنی درست.
5. استایل‌شیت چاپ اختصاصی (`print.scss`) جدا از استایل صفحه.
6. ۲۵ تصویر با `loading="lazy"` – شروع خوبی است، هرچند ناقص (بند بعد).
7. فونت فارسی با `woff2` و نسخه‌ی FaNum (ارقام فارسی درون فونت، نه با جایگزینی JS).
8. Laravel Mix با پیکربندی صریح و بیلد production در CI – یعنی asset دستی commit نمی‌شود.

۵.۲ نقاط ضعف

■ اندازه‌ی باندل – بزرگ‌ترین مشکل کارایی

`webpack.mix.js` شش نقطه‌ی ورود جداگانه تعریف کرده، اما هیچ استخراج vendor یا code splitting ندارد. نتیجه: **Chart.js و jQuery، Bootstrap، Popper** در هر باندل از نو تکرار می‌شوند.

فایل ساخته‌شده	حجم	محتوا
<code>category.js</code>	KB ۳۶۸	jQuery + Bootstrap + Chart.js + کد صفحه
<code>app.js</code>	KB ۳۰۹	jQuery + Bootstrap + Slick + کد مشترک
<code>blog.js</code>	KB ۳۰۲	تکرار کامل همان کتابخانه‌ها
<code>home.js</code>	KB ۱۳۴	تکرار
<code>cart.js</code>	KB ۹۸	تکرار
<code>profile.js</code>	KB ۹۲	تکرار
<code>app.css</code>	KB ۲۶۸	کل Bootstrap + کل Slick + Bootstrap Icons، بدون purge

یعنی کاربری که وارد صفحه‌ی دسته می‌شود، jQuery را دو بار دانلود می‌کند (یک بار در `app.js`، یک بار در `category.js`) و علاوه بر آن یک `jquery.min.js` جداگانه هم در همان صفحه بارگذاری می‌شود.

راه‌حل: `mix.extract(['jquery', 'bootstrap', 'chart.js'])` یک باندل vendor مشترک می‌سازد که یک بار دانلود و در تمام صفحات از کش خوانده می‌شود. صرفه‌جویی تخمینی: بیش از ۶۰٪ حجم جاوااسکریپت.

■ صفحه‌ی ورود، سنگین‌ترین صفحه‌ی سایت

صفحه‌ای که فقط یک ورودی شماره تلفن و یک دکمه دارد، **۱۴۲۳ کیلوبایت** دانلود می‌کند – بیشتر از صفحه‌ی اصلی با اسلایدر و جدول قیمت. علت: قالب‌های `auth/*` کل بسته‌ی قالب مدیریتی Metronic را import می‌کنند:

منبع	حجم	ضرورت
plugins.bundle.js	KB ۸۲۶	هیچ – صفحه فقط یک focus() جی کوئری دارد
bg-2.jpg	KB ۲۳۷	ترئینی؛ قابل تبدیل به WebP یا گرادیان CSS
style.bundle.rtl.css	KB ۱۴۴	هیچ
plugins.bundle.rtl.css	KB ۷۴	هیچ
scripts.bundle.js	KB ۵۷	هیچ

هر چهار اسکریپت هم **render-blocking** هستند (بدون async یا defer).

■ خطای جاوااسکریپت روی تمام صفحات

فایل live-time.js (که از طریق app.js در تمامی صفحات بارگذاری می‌شود) چنین است:

```
var span1 = document.getElementById('time_counter1');
function time() {
    ...
    span1.textContent = ...;    // ← span1 همیشه null است
}
setInterval(time, 1000);
```

عنصر #time_counter1 در header.blade.php داخل بلاک کامنت‌شده‌ی <div class="time"> است. پس span1 همیشه null است و تابع در همان خط اول throw می‌کند – هر ثانیه، برای همیشه، روی هر صفحه‌ی سایت. اندازه‌گیری زنده: ۹ خطای pageerror در ۶ ثانیه‌ی اول بارگذاری صفحه‌ی اصلی. دو پیامد: (الف) کنسول هر کاربر پر از خطا است و هر ابزار مانیتورینگ خطای واقعی را در این نویز گم می‌کند؛ (ب) چون throw قبل از رسیدن به span2 اتفاق می‌افتد، ساعت صفحه‌ی اصلی و صفحه‌ی قیمت هیچ‌وقت به‌روز نمی‌شود و روی مقدار hardcoded شده در قالب می‌ماند. اصلاح: یک شرط if (span1 && !span2) return; در ابتدای تابع، و برداشتن مقدار ثابت از قالب.

■ تصاویر

مورد	اندازه‌گیری
قالب فایل‌ها (صفحه اصلی)	۳۹ عدد ۱۱، PNG، ۳ عدد ۳، JPG، عدد SVG و فقط ۱ عدد WebP از مجموع ۵۴ تصویر
بدون width/height	۲۹ در صفحه اصلی، ۳۸ در ۱۹، /price در /blog – منبع اصلی CLS
بدون loading="lazy"	۴۴ از ۶۱ تصویر در /price؛ ۲۵ از ۴۲ در /blog
سنگین‌ترین فایل‌ها	2712GDN-119_Steel_Fruit_Cage... = ۵۴۹ KB · chain-link-fence.jpg = ۲۱۷ KB · about-us.jpg = ۱۲۰ KB
مجموع بار صفحه	/blog موبایل = ۱۸۴۹ KB که ۱۱۰۹ KB آن فقط تصویر است

آیکون‌های دسته‌بندی PNG هستند در حالی که خط‌نقاشی تک‌رنگ‌اند – تبدیل به SVG هم حجم را به کسری می‌رساند و هم در هر رزولوشنی تیز می‌ماند.

■ اسکریپت‌های شخص ثالث و شبکه

- هفت اسکریپت شخص ثالث روی هر صفحه: دو Google Analytics مجزا (G-4G781JNM07 و G-FPYB89P985 – یکی اضافی است)، Histats، Ahrefs، Analytics، Goftino، و gtagx۲.
- هیچ dns-prefetch، preconnect یا preload وجود ندارد – با وجود ۷ دامنه‌ی خارجی. افزودن preconnect برای googletagmanager.com و goftino.com کار چند دقیقه‌ای با اثر مستقیم روی LCP است.
- سه اسکریپت داخلی render-blocking در هر صفحه: sidemenu.js، app.js، و اسکریپت اختصاصی صفحه. هیچ‌کدام defer ندارند.
- ۶ تا ۸ اسکریپت inline در هر صفحه که مانع اعمال Content-Security-Policy سخت‌گیرانه می‌شوند.

- سیستم توکن وجود ندارد. فایل `_colors.scss` فقط ۸ خط است و نام‌ها ظاهری‌اند (`$red`، `$blue`) نه معنایی (`$color-danger`، `$color-` `primary`). هیچ مقیاس فاصله (`spacing scale`)، مقیاس تایپ، یا مقیاس سایه‌ای تعریف نشده.
- ۱۹ مورد `!important` – نشانه‌ی جنگ با خصوصیت (`specificity`).
- ۸۸ مورد `style="..."` درون‌خطی در قالب‌ها، از جمله برای رنگ‌های معنایی (`style="color: #23cf14"` برای نشانگر افزایش قیمت) که باید کلاس باشند.
- ناهماهنگی `breakpoint`ها. `_media-Queries.scss` شش متغیر تعریف می‌کند (`۳۷۵/۴۲۵/۷۶۸/۱۰۲۴/۱۴۴۰/۲۵۶۰`) اما بقیه‌ی کد از مقادیر دیگری استفاده می‌کند: `۹۹۲`، `۹۹۳`، `۱۳۰۰`، `۵۶۰`، `۵۷۶`. پنج نقطه‌ی شکست غیرسیستمی.
- حالت تاریک (`dark mode`) اصلاً وجود ندارد – نه به‌عنوان ایراد، بلکه به‌عنوان فرصت، چون سیستم توکن لازمش هم‌اکنون باید ساخته شود.

■ نقص‌های نشانه‌گذاری (markup)

- شناسه‌ی تکراری. `id="h-c-ignore"` روی چند سلول جدول قیمت تکرار شده – HTML نامعتبر.
- چیدمان جدول با `colspan`. جدول قیمت از `colspan="3"`، `colspan="6"` و... برای ساختن ستون‌بندی استفاده می‌کند، نه برای ادغام واقعی سلول. این معنانشناسی جدول را برای screen reader نابود می‌کند.
- `<img width="130px">` در چهار صفحه‌ی `auth` – صفت `width` در HTML باید عدد بدون واحد باشد؛ هیچ‌کدام `alt` هم ندارند.
- باقی‌مانده‌ی محیط توسعه. در `login.blade.php`: `var HOST_URL = "http://127.0.0.1:8000/login"`.
- مسیر نسبی به جای `asset()` در همان فایل: `src="{{'assets/plugins/global/plugins.bundle.js'}}"`.
- تعریف دوباره‌ی یک `section`. در `price.blade.php` دستور `@section('og_title', ...)` دو بار آمده و بار دوم مقدار توضیحات را می‌گذارد – یعنی عنوان اشتراک‌گذاری اجتماعی صفحه‌ی قیمت اشتباه است.

۶ تحلیل بک‌اند

۶.۱ نقاط قوت

- لایه‌بندی دامنه‌ای درست. کنترلرها به سه فضای نام روشن تقسیم شده‌اند: `UserPanel\`، `AdminPanel\`، `Site\`. مرزها شفاف است و هیچ کنترلر مشترکی بین آن‌ها نیست.
- سیستم نقش و دسترسی واقعی. مدل‌های `Role` و `Permission`، و هر ۹۶ روت پزل مدیریت جداگانه با `middleware("can:...")` محافظت شده‌اند – نه یک بررسی کلی «آیا ادمین است». این سطح از ریزدانگی در پروژه‌های این مقیاس نادر است.
- الگوی `Strategy` برای سبد خرید. `CartFactory` بین `GuestCart` (مبتنی بر کوکی) و `AuthCart` (مبتنی بر دیتابیس) انتخاب می‌کند، و کامنت بالای `CartController` دلیل تصمیم را برای توسعه‌دهنده‌ی بعدی توضیح داده. این مستندسازی درست است.
- `$fillable` روی هر ۴۰ مدل – نه `$guarded = []`. یعنی حفاظت از `mass assignment` به‌صورت پیش‌فرض «لیست سفید» است.
- ۵۹ فراخوانی `validate()` و ۸ کلاس `FormRequest` – پوشش اعتبارسنجی نسبتاً کامل است.
- لایه‌ی پشتیبان تمیز و مستند. کلاس‌های `Support\Asset`، `Support\Schema`، `Support\Brand` و میان‌افزار `ScrubLegacyBrand` با کامنت‌های دقیق که چرایی تصمیم را توضیح می‌دهند نه چیستی آن. کیفیت این کامنت‌ها به‌طور محسوسی بالاتر از بقیه‌ی مخزن است.
- `Eager loading` در مسیرهای داغ. `CategoryController` و `PriceListController` از `with()` تودرتو با انتخاب ستون (`select()`) استفاده می‌کنند – یعنی نویسنده مسئله‌ی `N+1` را می‌شناخته.
- خط لوله‌ی `CI/CD` واقعی. `push` به `main` بیلد می‌کند، از درخت زنده `snapshot` می‌گیرد، فقط فایل‌های تغییرکرده را آپلود می‌کند و پنج صفحه را `health-check` می‌کند. با توجه به اینکه سرور `SSH` ندارد و `Git hook` خود `cPanel` خراب است، این یک راه‌حل مهندسی‌شده‌ی قابل‌احترام است.
- تست پاک‌سازی برند با ۱۷۹ بررسی که هر ۱۳۰ قالب `Blade` را کامپایل و خروجی را `lint` می‌کند، و در `CI` روی هر `PR` اجرا می‌شود.
- اصلاح تزریق `Host` در `sitemap`. ساخت `URL` از `config/brand.php` به جای `URL::to()` و تست خودکاری که اگر کسی `URL::to` را برگرداند، شکست می‌خورد.

■ پشته‌ی از پشتیبانی خارج شده

مؤلفه	نسخه	پایان پشتیبانی	پیامد
PHP	7.4.33	نوامبر ۲۰۲۲	هیچ وصله‌ی امنیتی؛ بیش از ۳ سال بدون به‌روزرسانی
Laravel	x.8	ژانویه ۲۰۲۳	هیچ وصله‌ی امنیتی
CKEditor	4	ژوئن ۲۰۲۳	پشتیبانی فقط با قرارداد تجاری LTS
laravelium/sitemap	dev-archive	رهاشده	نویسنده بسته را abandoned اعلام کرده
jQuery	3.6	—	وابستگی سنگین که با Bootstrap 5 دیگر لازم نیست

این مهم‌ترین ریسک بلندمدت است. مسیر پیشنهادی مرحله‌ای: PHP 7.4 → 8.1 (سازگاری خوب)، سپس 8 → 9 → 10. هر گام جداگانه و با CI سبز.

■ باگ‌های کش – کش عملاً کار نمی‌کند

باگ ۱ – کلید ناهمخوان در Redirecting :

```
if (cache()->has('redirections')) // خوانده می‌شود ←
    return cache()->get('redirections');
$routes = Redirect::query()->get();
cache()->put('redirection', $routes, 20); // نوشته می‌شود ← redirection
```

کلید نوشتن و خواندن یکی نیست، پس شرط هرگز برقرار نمی‌شود. و چون این تابع در routes/web.php در سطح بارگذاری فایل روت فراخوانی می‌شود، یعنی یک پرس‌وجوی دیتابیس در هر درخواست سایت، حتی برای فایل‌های استاتیک مسیریابی‌شده. این توضیح مستقیم ۱۵۴۰ TTFB میلی‌ثانیه‌ای موبایل است.

باگ ۲ – کلید اشتباه در HomeController :

```
if (cache()->has("home.all_prices")) { ... } // هرگز true نمی‌شود
else {
    $all_prices = Price::query()->whereHas(...)->with(...)->take(10)->get();
    cache()->put("home.most_sales", $all_prices, $cacheTime); // کلید اشتباه ←
}
if (cache()->has("home.most_sales")) { // ولی مقدارش قیمت‌هاست true حالا
    $most_sales = cache()->get("home.most_sales"); // داده‌ی نوع اشتباه ←
}
```

دو اثر: کوئری اصلی صفحه‌ی اصلی هیچ‌وقت کش نمی‌شود، و کش most_sales با داده‌ی نوع دیگری آلوده می‌شود. (خوشبختانه \$most_sales در قالب استفاده نمی‌شود، پس فعلاً خطای قابل‌مشاهده‌ای تولید نمی‌کند – که خودش نکته‌ی بعدی است.)

باگ ۳ – TTL تصادفی: \$cacheTime = now()->second() مقدار «ثانیه‌ی جاری از دقیقه» را برمی‌گرداند، یعنی عددی تصادفی بین ۰ و ۵۹. اگر لحظه‌ی اجرا ثانیه‌ی صفر باشد، کش بلافاصله منقضی می‌شود. احتمالاً منظور now()->addMinutes(5) بوده است.

باگ ۴ – کوئری مرده: متغیرهای \$most_sales و \$most_new پرس‌وجو و به قالب ارسال می‌شوند، اما در home.blade.php هیچ استفاده‌ای ندارند (بخش مربوطه کامنت شده است). دو کوئری اضافی در هر بارگذاری صفحه‌ی اصلی.

■ کارایی پرس‌وجو

- بازسازی کامل sitemap در هر ذخیره. مدل‌های Category، Product و Article هر سه در boot() روی رویدادهای created/updated/deleted تابع Sitemap::generate() را صدا می‌زنند. این تابع تمام دسته‌ها (با فرزندان)، تمام محصولات (با دسته) و تمام مقالات را می‌خواند و برای هر دسته isLeaf() را که خودش یک کوئری است اجرا می‌کند. چون قیمت‌ها مرتب به‌روز می‌شوند، این عملیات سنگین به‌طور مداوم اجرا می‌شود. پیشنهاد: به یک job زمان‌بندی‌شده (مثلاً هر ۱۵ دقیقه) یا صف منتقل شود.

- **رابطه‌ی بازگشتی بدون کف.** `Category::children()` خودش `with('children')` دارد؛ یعنی بارگذاری آن، درخت را تا هر عمقی دنبال می‌کند. در `CategoryController::list()` این رابطه `eager load` می‌شود.
- **N+1 در منوی سراسری.** قالب‌های `partials/category/*` در حلقه `count($category->child)` صدا می‌زنند که رابطه را `lazy load` می‌کند — در هر صفحه‌ی سایت، چون منو در هدر است. متد `hasChild()` هم هر بار یک `COUNT` جداگانه اجرا می‌کند.
- **فقدان کامل ایندکس دیتابیس.** در هر ۵۰ فایل مهاجرت، تنها ایندکس‌های تعریف‌شده کلیدهای خارجی و جدول پیش‌فرض `password_resets` هستند. ستون‌هایی که ایندکس ندارند اما مرتب پرس‌وجو می‌شوند:

ستون	کجا استفاده می‌شود
<code>prices.price_at</code>	<code>orderBy</code> در صفحه‌ی اصلی و <code>/price</code> — باعث <code>file sort</code> روی کل جدول
<code>categories.slug</code>	جستجوی هر صفحه‌ی دسته (<code>where slug = ?</code>)
<code>products.slug</code>	جستجوی هر صفحه‌ی محصول
<code>products.status</code>	فیلتر در تقریباً هر کوئری محصول
<code>categories.status</code> ، <code>index_by_crawler</code>	ساخت <code>sitemap</code>

افزودن این ایندکس‌ها ارزان‌ترین بهبود کارایی موجود است.

- **پرس‌وجو درون قالب.** چهار فراخوانی `App\Models\...::count()` مستقیماً در `admin/index.blade.php` . لایه‌بندی را می‌شکند و کش‌ناپذیر است.
- **QUEUE_CONNECTION=sync** — یعنی ارسال پیامک و اعلان‌های سفارش درون چرخه‌ی درخواست HTTP اتفاق می‌افتد. اگر سرویس پیامک کند باشد، کاربر منتظر می‌ماند.

■ باگ‌های منطقی

محل	مشکل	شدت
<code>LoginController@VerifyCode</code>	<code>sleep(5)</code> در ابتدای متد. یک <code>worker</code> از <code>PHP-FPM</code> را برای ۵ ثانیه قفل می‌کند — ابزار ارزان برای از کار انداختن سرویس. اگر هدف کند کردن حمله بوده، <code>throttle</code> ابزار درست است.	زیاد
<code>LoginController@VerifyCode</code>	کد تأیید پس از ورود موفق حذف نمی‌شود — تا انقضای دو دقیقه‌ای دوباره قابل استفاده است.	زیاد
<code>LoginController@VerifyCode</code>	اگر رکورد کد پیدا نشود، <code>\$verification</code> برابر <code>null</code> است و <code>\$verification->code</code> خطای ۵۰۰ می‌دهد.	متوسط
<code>SliderController@update</code>	<code>image</code> با قانون <code>required</code> اعتبارسنجی می‌شود در حالی که تصویر قبلی هم نگه داشته می‌شود — یعنی لینک یک اسلاید بدون آپلود دوباره‌ی فایل قابل تغییر نیست.	متوسط
<code>CategoryController@update</code>	<code>\$request->has("delete_main_img")</code> برای مقدار خالی هم <code>true</code> است — ارسال یک چک‌باکس تیک‌نخورده تصویر دسته را حذف می‌کند.	زیاد
<code>GeneralSettingController@update</code>	مسیر حذف <code>favicon</code> قدیمی اشتباه ساخته می‌شود (بدون اسلش ابتدایی) — فایل‌های قدیمی هرگز پاک نمی‌شوند.	کم
<code>price.blade.php</code>	<code>@section('og_title')</code> دو بار تعریف شده؛ مقدار دوم توضیحات را جای عنوان می‌گذارد.	کم
<code>CollaborationController</code>	غلط املائی در نام کلاس (<code>Cotroller</code>)، و همزمان یک <code>CollaborationController</code> درست هم وجود دارد.	کم

■ کیفیت و ساختار کد

- **هیچ تست اپلیکیشنی وجود ندارد.** پوشه‌های `tests/Unit` و `tests/Feature` فقط شامل `ExampleTest.php` پیش‌فرض `Laravel` هستند. تنها تست واقعی مخزن، `brand-scrub-check.php` است که کارش عالی است اما دامنه‌اش فقط پاک‌سازی برند و کامپایل قالب‌هاست. هیچ تستی برای سبب خرید، ثبت سفارش، تخفیف، یا احراز هویت وجود ندارد.
- **تکرار گسترده.** ۷۶ کنترلر که اکثرشان همان الگوی `CRUD` را با کد کپی‌شده تکرار می‌کنند. هیچ لایه‌ی `Service` یا `Repository`، و هیچ `Base Controller` مشترکی وجود ندارد.

- **Mass assignment مستقیم از درخواست.** در `ArticleCategoryController` و `InformationController: $model->update($request->all())` با وجود `$fillable` خطر محدود است، اما الگوی درستی نیست.
- **قانون اعتبارسنجی بدون `anchor`.** `"level" => ["regex:(admin|user)"]` الگو را بدون `^` و `$` بررسی می‌کند، پس هر رشته‌ای که کلمه‌ی `admin` را در خود داشته باشد قبول می‌شود.
- **`unserialize()` روی داده‌ی کوکی** در `LoginController::checkCart()` چون میان‌افزار `EncryptCookies` فعال است و هیچ استثنایی ندارد، این در حال حاضر امن است – اما اگر روزی کسی `cart` را به لیست استثنا اضافه کند، به تزریق شیء PHP تبدیل می‌شود. `json_decode` انتخاب امن‌تری است.
- **پیکربندی محیط پیش‌فرض ناامن.** فایل `env.example` با `APP_ENV=local` و `APP_DEBUG=true` ارائه شده. اگر روزی روی سرور کپی شود، صفحه‌ی خطای `Ignition` تمام متغیرهای محیطی را نمایش می‌دهد.

۷ امنیت

آنچه درست است

CSRF روی تمام فرم‌ها فعال است. کوکی‌ها رمزنگاری می‌شوند و `secure`، `httponly` و `samesite=lax` دارند. `$fillable` روی هر ۴۰ مدل ورود بدون رمز عبور (OTP) یعنی هیچ هش رمزی برای نشت وجود ندارد. مجوزدهی ریزدانه روی ۹۶ روت ادمین تنها ۲۶ خروجی `escape` نشده (`{!! !!}`) در ۱۳۰ قالب، همگی روی محتوای مدیریتی نه ورودی کاربر پرس‌وجوی خام تقریباً وجود ندارد (فقط ۲ مورد `DB::raw` بدون ورودی کاربر). آسیب‌پذیری تزریق `Host` در `sitemap` شناسایی و اصلاح شده.

#	یافته	توضیح و اثر	شدت
S1	آپلود SVG مجاز است	در ۱۷ نقطه‌ی اعتبارسنجی <code>svg</code> در فهرست <code>mimes</code> است، از جمله <code>avatar</code> و <code>doc_file</code> در پروفایل کاربر و <code>attached</code> در تیکت – یعنی کاربر عادی می‌تواند آپلود کند. فایل SVG می‌تواند <code><script></code> داشته باشد و چون از همان دامنه سرو می‌شود، در بستر امنیتی سایت اجرا می‌شود → XSS ذخیره‌شده و ربودن نشست ادمین. اصلاح: <code>svg</code> را از تمام فهرست‌ها حذف کنید؛ اگر لازم است، فایل را با <code>Content-Disposition: attachment</code> یا از یک دامنه‌ی جدا سرو کنید.	بحرانی
S2	بدون محدودیت نرخ روی احراز هویت	<code>Ratelimiter</code> فقط برای گروه <code>api</code> پیکربندی شده. روت‌های <code>/verify-phone</code> ، <code>/submit-phone</code> و <code>/resend-phone</code> هیچ <code>throttle</code> ندارند. فضای کد ۶ رقمی یک میلیون حالت است با پنجره‌ی دو دقیقه‌ای. همچنین <code>/submit-phone</code> بدون محدودیت یعنی هزینه‌ی پیامک قابل سوءاستفاده است. اصلاح: <code>throttle:5,1</code> روی <code>verify</code> و <code>throttle:3,10</code> روی <code>submit</code> .	بحرانی
S3	کد تأیید پس از استفاده باطل نمی‌شود	پس از ورود موفق، رکورد کد در جدول <code>verificationcodes</code> باقی می‌ماند و تا انقضای دو دقیقه‌ای قابل استفاده‌ی مجدد است.	زیاد
S4	هیچ هدر امنیتی HTTP وجود ندارد	پاسخ سرور بررسی شد: نه <code>Strict-Transport-Security</code> ، نه <code>Content-Security-Policy</code> ، نه <code>X-Content-Type-Options</code> ، نه <code>Referrer-Policy</code> . سایت در برابر <code>clickjacking</code> و <code>MIME sniffing</code> محافظت نشده. اصلاح: یک میان‌افزار کوچک که این پنج هدر را اضافه کند – کار یک ساعته با اثر زیاد.	زیاد
S5	<code>TrustHosts</code> هنوز غیرفعال است	خط ۱۷ فایل <code>app/Http/Kernel.php</code> کامنت است. <code>Laravel</code> هر مقدار <code>Host</code> را می‌پذیرد، پس <code>url()</code> ، <code>asset()</code> و لینک‌های بازبایی همچنان از هدر غیرقابل‌اعتماد ساخته می‌شوند. <code>sitemap</code> اصلاح شده اما ریشه‌ی مشکل باز است. پیش‌نیاز: ابتدا باید <code>APP_URL</code> روی سرور تأیید شود، وگرنه فعال‌سازی، سایت را ۴۰۳ می‌کند.	زیاد
S6	<code>sleep(5)</code> در مسیر ورود	هر درخواست تأیید کد، یک <code>worker</code> از <code>PHP-FPM</code> را ۵ ثانیه اشغال می‌کند. با تعداد محدود <code>worker</code> ، چند ده درخواست همزمان می‌تواند سایت را از دسترس خارج کند.	زیاد
S7	معافیت CSRF روی آپلود ویرایشگر	<code>admin/upload-image</code> در فهرست استثنای <code>VerifyCsrfToken</code> است. هرچند پشت احراز هویت ادمین است، اما یک سایت مخرب می‌تواند مرورگر ادمین لاگین‌کرده را وادار به آپلود فایل کند.	متوسط
S8	فایل‌های آپلودی بازنگذاری نمی‌شوند	<code>Image::upload_pic()</code> فایل را مستقیماً به <code>public_path()</code> منتقل می‌کند بدون بازسازی تصویر. نام فایل هم از <code>getClientOriginalName()</code> گرفته می‌شود.	متوسط

#	یافته	توضیح و اثر	شدت
S9	احراز هویت تک‌عاملی و تک‌کاناله برای مدیریت	ورود به پنل مدیریت فقط با پیامک است. اگر سرویس پیامک از کار بیفتد یا سیم‌کارت مالک مشکل پیدا کند، هیچ راه پشتیبانی برای دسترسی مدیریتی وجود ندارد. حمله‌ی SIM swap هم مسیر کاملی به پنل مدیریت می‌دهد.	متوسط
S10	بدون گزارش ممیزی (audit log)	هیچ ثبتی از اینکه کدام ادمین چه چیزی را کی تغییر داده وجود ندارد. با توجه به اینکه قیمت‌ها مستقیماً به قیمت فروش تبدیل می‌شوند، این یک شکاف کنترلی است.	متوسط

۸ داشبورد مدیریت

این بخش از روی کد تحلیل شده است – ورود زنده به پنل نیازمند کد پیامکی دوقیقه‌ای روی موبایل مالک بود.

۸.۱ نقاط قوت

- پوشش عملیاتی کامل. ۹۶ آیتم منو در ۱۳ دسته: کاربران، محصولات، مقالات، سفارشات، پرداخت‌ها، تنظیمات، نظرات، خبرنامه، تخفیف، تگ، تیکت، همکاری، ویدئو. تقریباً هیچ کاری نیست که مدیر مجبور باشد برای آن به دیتابیس مراجعه کند.
- دسترسی ریزدانه‌ی واقعی – هر روت جداگانه با `can` محافظت شده، و صفحه‌ی مدیریت نقش‌ها اجازه‌ی ساخت نقش سفارشی می‌دهد.
- ویرایش گروهی قیمت با اکسل (ExcelController) – برای کسب‌وکاری که روزانه ده‌ها قیمت را به‌روز می‌کند، این ویژگی درست انتخاب شده.
- داشبورد با اطلاعات عملیاتی مفید: ۴ کارت شاخص، آخرین ۱۰ سفارش، آخرین ۱۰ تیکت، و نظرات تأییدنشده‌ی سه نوع محتوا در تب‌های جدا – یعنی کارهای در انتظار اقدام در دید مدیر است.
- مودال تأیید حذف در `layout/modal.blade.php` تعریف شده.
- ۴۷ از ۸۲ فرم بلوک `@error` برای نمایش خطای اعتبارسنجی دارند.

۸.۲ نقاط ضعف

مورد	یافته و پیشنهاد	شدت
حجم دارایی‌ها	پوشه‌ی <code>assets</code> برابر ۶۳ مگابایت است. تنها دو فایل <code>plugins.bundle.js</code> (۴ مگابایت) و <code>style.bundle.rtl.css</code> (۲.۱ مگابایت) در هر بارگذاری صفحه‌ی مدیریت دانلود می‌شوند. قالب Metronic کامل بارگذاری می‌شود در حالی که کسری از افزونه‌هایش (<code>datatables</code> ، <code>tinymce</code> ، <code>fullcalendar</code> ، <code>leaflet</code> ، <code>jqvmap</code> ، <code>kanban</code> ، <code>jstree</code>) استفاده می‌شود.	زیاد
پیدا کردن یک آیتم	۹۶ آیتم منو بدون هیچ جعبه‌ی جستجویی (شمارش <code><input></code> در سایدبار: صفر). افزودن یک <code>command palette</code> یا فیلتر ساده‌ی منو، کم‌هزینه‌ترین بهبود تجربه‌ی مدیر است.	زیاد
لوگوی برند قبلی	<code>images/text-logo-light.png</code> در سایدبار و هدر موبایل پنل – همان مشکل صفحات ورود.	زیاد
بازخورد خطای فرم	۳۵ از ۸۲ قالب هیچ بلوک <code>@error</code> ندارند. در این فرم‌ها اگر اعتبارسنجی شکست بخورد، مدیر به صفحه برمی‌گردد بدون اینکه بداند چه چیزی اشتباه بوده.	زیاد
کوئری در قالب	چهار <code>count()</code> مستقیم در <code>admin/index.blade.php</code> . باید به کنترلر منتقل و کش شود.	متوسط
داشبورد بدون روند	کارت‌های شاخص فقط یک عدد لحظه‌ای نشان می‌دهند – بدون مقایسه با دوره‌ی قبل، بدون نمودار روند. برای کسب‌وکار قیمت‌محور، یک نمودار «روند قیمت میانگین» و «سفارشات هفتگی» ارزش زیادی اضافه می‌کند.	متوسط
ویرایشگر متن	CKEditor 4 که از ژوئن ۲۰۲۳ فقط با قرارداد تجاری پشتیبانی می‌شود. ضمناً رفتار <code>form.submit</code> را <code>patch</code> می‌کند که ویرایشگر برنامه‌نویسی‌شده‌ی فرم‌ها را خطرناک می‌سازد.	متوسط

مورد	یافته و پیشنهاد	شدت
بدون audit log	هیچ ردی از اینکه کدام کاربر چه رکوردی را کی تغییر داد باقی نمی‌ماند.	متوسط
واکنش‌گرایی	پنل روی موبایل با <code>kt_aside_mobile_toggle</code> کار می‌کند، اما جدول‌های داده‌ی سنگین (سفارشات، محصولات، قیمت‌ها) برای صفحه‌ی کوچک بهینه نشده‌اند.	کم
دو فونت متناقض	پی‌کربندی <code>KTAppSettings</code> فونت را <code>Poppins</code> اعلام می‌کند (فونت لاتین) در حالی که رابط کاملاً فارسی است.	کم

۹ نقشه راه اصلاح – چهار موج

موج ۱ – بُرد سریع (۲ تا ۳ روز کاری - بیشترین اثر به‌ازای هزینه)

#	اقدام	تلاش	اثر
۱.۱	جایگزینی لوگوی «آهن امن» در ۴ صفحه‌ی <code>auth</code> و ۲ محل پنل مدیریت + افزودن <code>alt</code> و اصلاح <code>width="130px"</code>	۱ ساعت	حذف آخرین اثر برند قبلی از دید کاربر
۱.۲	افزودن نگهبان <code>null</code> در <code>live-time.js</code> و برداشتن ساعت <code>hardcode</code> از قالب	۱۵ دقیقه	پایان خطای هرثانیه‌ای؛ ساعت واقعاً کار می‌کند
۱.۳	اصلاح سه باگ کش (کلید <code>redirections</code> ، کلید <code>home.all_prices</code> ، کلید <code>TTL</code>)	۲ ساعت	حذف یک کوئری از هر درخواست؛ کاهش محسوس <code>TTFB</code>
۱.۴	حذف <code>svg</code> از ۱۷ فهرست <code>mimes</code>	۳۰ دقیقه	بستن مسیر <code>XSS</code> ذخیره‌شده
۱.۵	افزودن <code>throttle</code> به روت‌های ورود و باطل کردن کد پس از مصرف	۲ ساعت	بستن <code>brute-force</code> و سوءاستفاده از هزینه‌ی پیامک
۱.۶	میان‌افزار هدرهای امنیتی (<code>HSTS</code> ، <code>X-Frame-Options</code> ، <code>X-Content-Type-Options</code> ، <code>Referrer-Policy</code>)	۱ ساعت	حفاظت پایه‌ای مرورگر
۱.۷	افزودن ایندکس دیتابیس به ۶ ستون پرمصرف	۲ ساعت	ارزان‌ترین بهبود کارایی موجود
۱.۸	حذف <code>sleep(5)</code> ؛ حذف <code>GA4</code> تکراری و <code>Histats</code>	۳۰ دقیقه	آزادسازی <code>worker</code> ؛ سبک‌تر شدن هر صفحه
۱.۹	افزودن <code>preconnect</code> برای دامنه‌های شخص ثالث + <code>defer</code> روی اسکریپت‌های داخلی	۱ ساعت	بهبود مستقیم <code>LCP</code>
۱.۱۰	افزودن <code><h1></code> به <code>/blog</code> ، <code>/about</code> ، <code>/contact</code> و <code>meta description</code> به صفحاتی که ندارند	۱ ساعت	سنو و دسترس‌پذیری

موج ۲ – نجات تجربه‌ی موبایل (۱ تا ۲ هفته - بیشترین اثر روی کاربر)

۱. بازسازی مقیاس تایپوگرافی. `html { font-size: 100% }` و ساخت مقیاس تایپ با `clamp()`. این تغییر باید با بازبینی بصری کامل تمام صفحات همراه شود چون فاصله‌ها هم `rem` هستند. مهم‌ترین تک‌اقدام کل این گزارش.
۲. تبدیل جدول قیمت به کارت زیر ۷۶۸ پیکسل. هر محصول یک کارت: نام (تیترا)، قیمت (بزرگ)، نوسان (چپ رنگی + آیکون)، دکمه‌ی خرید تمام‌عرض.
۳. نمایش لوگو در هدر موبایل (برداشتن `d-none d-lg-block` و ساخت یک نسخه‌ی کوچک‌تر).
۴. افزودن `width` و `height` به تمام تصاویر – هدف: `CLS` زیر ۰.۱ در همه‌ی صفحات.
۵. بزرگ کردن هدف‌های لمسی به حداقل ۴۴×۴۴ (بخش زیادی از این خودکار با اصلاح ۱ حل می‌شود).
۶. اصلاح سرریز افقی `/blog` و بازچینش کاشی‌های دسته در `/price`.
۷. سبک‌سازی صفحات `auth` – جدا کردن آن‌ها از باندل `Metronic`؛ یک استایل‌شیت کوچک اختصاصی.

8. بهینه‌سازی تصاویر: تبدیل به WebP، فشرده‌سازی، تبدیل آیکون‌های دسته به `loading="lazy"`، SVG، روی همه‌ی تصاویر پایین `fold`.

موج ۳ – سلامت فنی (۲ تا ۴ هفته)

1. استخراج باندل `vendor` با `mix.extract()` – تخمین کاهش بیش از ۶۰٪ حجم JS.
2. `Purge` کردن CSS – از ۲۶۸ کیلوبایت به کسری از آن.
3. انتقال `Sitemap::generate()` به یک `job` زمان‌بندی‌شده به جای اجرا در هر ذخیره.
4. ساخت سیستم توکن طراحی: رنگ‌های معنایی، مقیاس فاصله (۴/۸)، مقیاس تایپ، مقیاس سایه، و یکسان‌سازی breakpointها روی چهار نقطه.
5. حل N+1 منوی سراسری – درخت دسته یک بار کش شود، نه در هر رندر پرس‌وجو.
6. افزودن پوشش تست برای مسیرهای پولی: سبد خرید، ثبت سفارش، اعمال تخفیف، احراز هویت.
7. فعال‌سازی `TrustHosts` پس از تأیید `APP_URL` روی سرور.
8. افزودن جستجوی منو و بلوک `@error` به ۳۵ فرم فاقد آن در پنل مدیریت.
9. افزودن `aria-label` به دکمه‌های فقط آیکون، `skip link`، و `th scope` به جدول‌ها.

موج ۴ – سرمایه‌گذاری بلندمدت (۱ تا ۲ ماه)

1. ارتقای پشته: 8.1 → 7.4، PHP، سپس 10 → 9 → 8، Laravel. مرحله‌ای، با CI سبز در هر گام.
2. حل مسئله‌ی تازگی داده. یا قیمت‌ها واقعاً روزانه به‌روز شوند، یا تیترا «لحظه‌ای» به چیزی صادقانه تغییر کند. این تنها یافته‌ای است که راه‌حلش فنی نیست، اما بیشترین اثر را روی اعتماد دارد.
3. افزودن `Product` در `schema.org` و `Offer` به صفحه‌ی `/price` – بزرگ‌ترین فرصت سنوئی استفاده‌نشده‌ی سایت.
4. `audit log` برای تغییرات مدیریتی، به‌ویژه قیمت‌ها.
5. جایگزینی `CKEditor 4` با `CKEditor 5` یا `TipTap`.
6. حذف وابستگی `Bootstrap 5` – `jQuery` دیگر به آن نیاز ندارد.
7. لایه‌ی `Service/Repository` برای کاهش تکرار در ۷۶ کنترلر.
8. حالت تاریک پس از آماده شدن سیستم توکن (موج ۳).

۱۰ پیوست: اعداد اندازه‌گیری‌شده

۱۰.۱ کارایی – موبایل ۳۷۵×۸۱۲

صفحه	LCP	CLS	TTFB	بار کل	تصویر	تسک بلند
صفحه اصلی	۲۴۲۸ms	۰.۴۰۸	۱۵۴۰ms	KB ۱۱۶۶	KB ۸۱۱	۸ (۱۵۸۶ms)
price/	۷۴۰ms	۰.۷۲۶	۴۴۸ms	KB ۲۵	KB ۱۹	۵ (۳۶۳ms)
blog/	۱۰۲۰ms	۰	۳۶۳ms	KB ۱۸۴۹	KB ۱۱۰۹	۷ (۴۹۵ms)
about/	۷۲۴ms	۰.۳۲۵	۳۷۰ms	KB ۸۳	KB ۶۵	۶ (۴۲۸ms)
contact/	۵۶۴ms	۰.۰۸۳	۲۹۸ms	—	—	۹ (۸۰۲ms)
login/	۱۰۵۶ms	۰	۳۵۰ms	KB ۱۴۲۳	KB ۲۸	۲ (۲۷۸ms)
/category/	۱۴۸۴ms	۰	۱۲۲۷ms	—	—	۳ (۲۱۹ms)
category/سیم-خاردار	۶۸۴ms	۰.۰۱۵	۴۲۰ms	KB ۱۶۲	KB ۱۸	۷ (۷۹۸ms)

۱۰.۲ دسترس‌پذیری – شمارش موبایل

صفحه	متن زیر ۱۴px	هدف لمسی کوچک	تصویر بدون ابعاد	آیکون بدون برجسب	h1
صفحه اصلی	۱۳۷	۱۰۶ / ۶۳	۲۹	۱۶	۱
price/	۱۸۵	۱۴۱ / ۹۲	۳۸	۲۴	۱
category/سیم-خاردار	۱۲۵	۸۶ / ۴۹	۶	۷	۱
blog/	۹۳	۸۲ / ۴۸	۱۹	۴	۰
/category/	۶۸	۶۶ / ۳۶	۱۸	۴	۱
contact/	۵۷	۶۲ / ۳۱	۴	۵	۰
about/	۵۱	۵۴ / ۲۳	۱۳	۴	۰
login/	۲	۴ / ۳	۱	۰	۰

۱۰.۳ مقیاس کدبیس

۵۰ مهاجرت	۴۰ مدل	۷۶ کنترلر	۱۳۰ قالب Blade
۰ تست اپلیکیشن	۵۹ فراخوانی validate	۹۶ روت ادمین	۳۸۱۸ خط SCSS

۱۰.۴ ابزار و روش راستی‌آزمایی

هر ادعای عددی در این گزارش با یکی از این دو روش قابل بازتولید است:

- **اندازه‌گیری زنده:** Chromium headless با PerformanceObserver برای largest-contentful-paint ، layout-shift و longtask ؛ و پیمایش DOM برای اندازه‌ی محاسبه‌شده، ابعاد getBoundingClientRect و محاسبه‌ی نسبت کنتراست بر پایه‌ی فرمول درخشندگی نسبی WCAG.
 - **تحلیل ایستا:** خواندن مستقیم کد منبع در مخزن ahanamn-src ، با ارجاع فایل و شماره‌ی خط برای هر یافته.
- معیارهای بررسی UI/UX از چک‌لیست ده‌گانه‌ی اولویت‌بندی‌شده‌ی ui-ux-pro-max گرفته شده — به‌ترتیب: دسترس‌پذیری، لمس و تعامل، کارایی، انتخاب سبک، چیدمان و واکنش‌گرایی، تایپوگرافی و رنگ، انیمیشن، فرم و بازخورد، الگوهای ناوبری، و نمودار و داده.

جمع‌بندی نهایی

سپاهان فلز یک اسکلت فنی خوب دارد که با چند تصمیم اشتباه در لایه‌ی ارائه و چند باگ کوچک اما پرتکرار، زیر ظرفیت خودش کار می‌کند. هیچ‌کدام از ده یافته‌ی بحرانی نیازمند بازنویسی نیست — نه معماری، نه دیتابیس، نه خط لوله‌ی استقرار. **موج ۱ در کمتر از سه روز کاری قابل انجام است و پس از آن، موج ۲ (اصلاح مقیاس فونت و جدول موبایل) تنها تغییری است که کاربر واقعی بلافاصله آن را حس خواهد کرد.**